

Problem Statement 13 — Patient Health Record Consent Management System

Requirements Table

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
FR-001	Functional	The system shall allow patients to grant time-bounded (e.g., 24-hour) access permissions for specific diagnostic records to verified clinic doctors.	High	Pass: Clinic access automatically revokes upon expiry timestamp. Fail: Clinic accesses records after consent expiration.	Core function enabling patient-controlled, time-limited data sharing.
FR-002	Functional	The system shall allow a patient to revoke a previously granted access permission at any time before its scheduled expiry.	High	Pass: A clinic's access attempt is denied within 5 seconds of the patient tapping "Revoke". Fail: Clinic can still view the record after revocation.	Patients must retain immediate, continuous control over who can view their health data.
FR-003	Functional	The system shall require a clinic doctor to submit an access request specifying patient ID, record type, and reason for access before consent can be granted.	Medium	Pass: A request submitted without a reason field is rejected with an error message. Fail: A request lacking a reason is accepted and forwarded to the patient.	Capturing purpose-of-access supports informed patient decisions and audit accountability.
FR-004	Functional	The system shall send the patient a notification (in-app, SMS, or email) at least one hour before an active consent grant expires.	Medium	Pass: Notification logs show a reminder sent 55-65 minutes before every grant's expiry timestamp. Fail: No reminder is logged, or it falls outside that window.	Gives patients a timely opportunity to extend or let access lapse before it expires.
FR-005	Functional	The system shall allow a patient to view a complete, filterable audit trail of all consent grants, revocations, and record accesses linked to their account.	High	Pass: Filtering the audit trail by a date range returns all matching events within 3 seconds. Fail: Events are missing from results or the query fails.	Transparency into access history builds patient trust and supports regulatory compliance.
FR-006	Functional	The system shall allow a patient to designate specific diagnostic records as "Emergency Access" eligible, enabling any verified clinic doctor to request immediate break-glass override access during a medical emergency, with mandatory justification capture.	High	Pass: An emergency override request against an eligible record is granted within 30 seconds, requires a justification note, and is immediately logged with the requesting doctor's ID and timestamp; the patient is notified as soon as connectivity allows. Fail: Access is granted without a justification note, without an immediate audit log entry, or against a record not flagged as emergency-eligible.	Ensures life-saving access to critical records when a patient is incapacitated or unreachable, while preserving accountability through justification capture and immediate logging.
NFR-001	Nonfunctional (Performance & Security)	All consent grant, revoke, and access events shall be permanently written to an append-only audit trail.	High	Pass: Benchmarking tests confirm target latency and security standards are met under simulated peak load.	Guarantees a tamper-evident record of every consent-related action for compliance and dispute resolution.
NFR-002	Nonfunctional (Security)	All patient health records and consent data shall be encrypted using AES-256 at rest and TLS 1.2 or higher in transit.	High	Pass: A security scan confirms no record is stored or transmitted unencrypted. Fail: Any record is found in plaintext at rest or in transit.	Protects sensitive health data from unauthorized disclosure and satisfies healthcare data-protection regulations (e.g., HIPAA, India's DPDP Act).

Use-Case Flow Specification

Patient Health Record Consent Management System

Use Case Name: Give access permission

Primary Actor: Patient

Supporting Actors: System (Notification Service, Audit Trail Service), Clinic Doctor (recipient of access)

Includes: User Authentication

Extends: This use case can be extended by Custom Expiry Duration and, on emergencies, by Emergency Access Override.

Preconditions

- The patient has a registered account and has completed identity verification.
- The clinic doctor/clinic has an active, verified profile in the system.
- The patient's diagnostic record(s) already exist in the system.

Postconditions

- A time-bound access grant is created and linked to the specified record(s) and clinic doctor.
- The grant, including its expiry timestamp, is written to the append-only audit trail.
- The clinic doctor is able to access the specified record(s) until expiry or revocation.

Main Success Scenario

1. Patient logs in and selects "Manage Consent" from the dashboard (includes UC-01: Authenticate User).
2. System displays a list of the patient's diagnostic records and a "Grant Access" option.
3. Patient selects the record(s) to share and searches for the verified clinic doctor by name or clinic ID.
4. System displays the doctor's verified profile for confirmation.
5. Patient sets the access duration (default 24 hours) or optionally customizes it (extends UC-06: Set Custom Expiry Duration).
6. Patient confirms the grant request.
7. System validates the request, creates the time-bound access permission, and records the event in the audit trail.
8. System displays a confirmation message to the patient and notifies the clinic doctor that access has been granted.
9. Use case ends successfully.

Alternate Flow - 4a: Clinic Doctor Not Verified

- System cannot find a verified profile matching the search criteria.
- System displays a "Doctor not verified / not found" message and prevents the grant from proceeding.
- Patient is returned to step 3 to search again or cancel the request.

Alternate Flow - 7a: Validation Failure

- System detects invalid input (e.g., expiry duration exceeds the allowed maximum).
- System displays a specific error message identifying the invalid field.
- Patient corrects the input and resubmits, returning to step 6.

Use Case Name: Emergency Access Override

Primary Actor: Clinic Doctor

Supporting Actors: System (Audit Trail Service, Notification Service), Patient (notified post-hoc)

Includes: User Authentication

Extends: Give access permission (alternate, emergency path when standard consent cannot be obtained in time)

Preconditions

- The clinic doctor has an active, verified profile in the system.
- The patient's diagnostic record(s) already exist in the system.
- At least one of the patient's records has been flagged as "Emergency Access eligible".

Postconditions

- A temporary emergency access grant is created for the requesting doctor, scoped to the emergency-eligible record(s).
- The override event, including the doctor's ID, timestamp, and justification note, is written to the append-only audit trail.
- The patient is notified of the emergency access grant as soon as they are reachable.

Main Success Scenario

1. Clinic doctor logs in and selects "Request Emergency Access" (includes UC-01: Authenticate User).
2. System prompts the doctor to enter the patient identifier and a mandatory justification note describing the emergency.
3. System verifies the doctor's credentials and checks whether the specified record(s) are flagged as emergency-eligible.
4. System immediately grants temporary override access to the flagged record(s) and records the event, including justification, in the audit trail.
5. System displays the record(s) to the doctor and confirms the grant along with its automatic expiry (e.g., 4 hours or until manually closed).
6. System notifies the patient of the emergency access grant, including the doctor's identity and justification, via their preferred channel.
7. Use case ends successfully.

Alternate Flow - 3a: Record Not Emergency-Eligible

- System finds that none of the specified records are flagged as emergency-eligible.
- System denies the override request and displays a message directing the doctor to the standard access-request flow (FR-003).
- Use case ends without granting access.

Alternate Flow - 2a: Missing Justification

- Doctor attempts to submit the request without a justification note.
- System rejects the submission and highlights the justification field as required.
- Doctor enters a justification and resubmits, returning to step 3.

Use-Case Diagram: Patient Health Record Consent Management System

Legend:

— association

